

Работа со служебными пользователями

У нас есть механизм работы приложений через сервисных (служебных) пользователей. В этом случае для приложения создается отдельный пользователь (сервисный) все обращения к приложению возможны только от лица этого пользователя. Настройки доступа этого сервисного пользователя полностью ассоциируются с настройками доступа приложения.

Тут-то и появляется потенциальная проблема безопасности. Иногда, пользователям (П) нашей системы нужно залогиниться под этим сервисным пользователем (С). Поскольку у (С) часто довольно широкие полномочия, то (П) может повысить себе привилегии, залогинившись под (С). Поэтому нельзя позволять (П) логиниться под (С), если его полномочия ниже, чем у (С).

Хорошая новость: у нас есть механизм для предотвращения такой ситуации. В случае, если служебному пользователю назначена роль, при попытке под ним залогиниться производится проверка: сверяются права сервисного пользователя и пользователя, который логинится, и логин запрещается, если происходит повышение прав.

Поэтому, если для вашего приложения необходим **сервисный пользователь**, запомните главное: **нужно назначить ему роль!**

А если забудете, то наши автотесты это обнаружат и мы выпишем ошибку.